

Ares: Phát hiện toàn diện tấn công Path Hijacking dựa trên Cây định tuyến

Nguồn: Yinxiang Tao, Chengwan Zhang, Changqing An, Shuying Zhuang, Jilong Wang, Congcong Miao — “Ares: Comprehensive Path Hijacking Detection via Routing Tree”, 34th USENIX Security Symposium, 13–15/8/2025, Seattle, WA, USA.

Tài liệu này: bản giảng giải bằng tiếng Việt, viết để bạn hiểu rõ và trình bày lại cho lớp.

Đọc thế nào cho nhanh: Nếu bạn chỉ có 10 phút, hãy đọc **Phần 0 (Tóm tắt một trang)** và **Phần 4 (Ý tưởng cốt lõi: OPRT)**. Hai phần đó đủ để bạn kể lại được “bài báo này làm gì và hay ở chỗ nào”. Các phần còn lại là chi tiết kỹ thuật để trả lời câu hỏi.

0. Tóm tắt một trang — nếu chỉ nhớ được bấy nhiêu

Vấn đề. Internet gồm hơn 80.000 mạng lớn gọi là AS (Autonomous System — Hệ thống tự trị). Các AS trao đổi đường đi với nhau bằng giao thức BGP. BGP được thiết kế từ những năm 1990 với giả định “ai nói gì cũng tin”, không có cơ chế xác thực. Vì vậy một AS xấu có thể thông báo sai lệch để kéo lưu lượng của người khác về phía mình — gọi là **prefix hijacking** (chiếm quyền dải địa chỉ).

Loại tấn công khó nhất hiện nay. Kiểu cũ (*origin hijacking*) là kẻ tấn công tự nhận mình sở hữu dải IP của nạn nhân — dễ bị phát hiện vì gây xung đột “một dải IP có hai chủ” (MOAS). Kiểu mới (*path hijacking*) tinh vi hơn: kẻ tấn công **vẫn ghi đúng tên nạn nhân ở cuối đường đi**, chỉ bịa ra đoạn đường dẫn tới nạn nhân. Không có xung đột chủ sở hữu, nên mọi công cụ kiểm tra chủ sở hữu (RPKI-ROV) đều bó tay.

Điểm yếu của các hệ thống hiện có. Mỗi hệ thống chỉ bắt được một phần: hệ dựa vào “liên kết giả” bó tay trước kiểu Defcon (không tạo liên kết giả nào); hệ dựa vào luật valley-free báo nhầm rất nhiều; hệ dò bằng ping/traceroute không bắt được tấn công kiểu man-in-the-middle; Artemis bắt được hết nhưng chỉ dùng được cho chính AS đã cài nó, không giám sát được toàn Internet.

Ý tưởng cốt lõi của bài báo (đây là câu quan trọng nhất cả bài). Các nhà quan sát BGP công cộng (vantage point — VP) nhìn thấy đường đi tới một dải IP. Gom tất cả đường đi đó lại ta được một **cây định tuyến quan sát được — OPRT** (Observed Prefix’s Routing Tree). Nhóm tác giả đo đạc và phát hiện: **hơn 80% AS chỉ có dưới 10 dạng cây OPRT**, vì mỗi AS quảng bá các dải IP của mình theo vài chính sách giống nhau. Khi bị path hijacking, đường đi tới dải IP bị tấn công đổi khác → **sinh ra một cây OPRT mới lạ**. Vậy chỉ cần **đếm số cụm cây OPRT của mỗi AS; số cụm tăng đột ngột = nghi ngờ bị hijack**.

Hệ thống Ares. Cứ 5 phút, Ares dựng lại cây OPRT cho các AS từ dữ liệu BGP công cộng (RIPE RIS), gom cụm các cây giống nhau bằng **khoảng cách chỉnh sửa có trọng số** (weighted edit distance), rồi so số cụm với lần trước. Cụm mới xuất hiện → đưa qua **4 luật lọc kinh nghiệm (H1-H4)** để loại bỏ thay đổi bình thường → còn lại là cảnh báo hijack.

Kết quả. Phát hiện **12/12** sự kiện tấn công có thật trong lịch sử, mỗi vụ trong vòng 5 phút. Mô phỏng 1.706 sự kiện: recall trung bình **97,2%** (exact prefix) và **99,3%** (sub-prefix) với mục tiêu là AS Tier-1 và AS nội dung, FPR chỉ **1,06%** — vượt xa Metis, DFOH, BEAM. Chạy thật 1 tháng trên Internet: chỉ **2,31 cảnh báo/giờ**, độ chính xác 63%, xử lý 5 phút dữ liệu hết 6,33 giây.

Vì sao đáng chú ý. Đây là hệ thống **đầu tiên** bắt được **tất cả** các biến thể của path hijacking (kể cả Defcon), lại chạy được trên phạm vi **toàn Internet** mà không cần AS nào phải cài đặt gì, không cần thông tin bí mật, và nhẹ hơn các phương pháp học máy.

Mục lục

- Kiến thức nền: BGP và AS — giải thích cho người mới
- Prefix hijacking: kiểu cũ và kiểu mới
- Phân loại tấn công (bảng quan trọng cần thuộc)
- Vì sao các hệ thống cũ thất bại
- Ý tưởng cốt lõi: OPRT và quan sát của nhóm tác giả
- Bốn thách thức kỹ thuật
- Thiết kế hệ thống Ares (chi tiết từng khối)
- Thực nghiệm và kết quả
- Bốn ca nghiên cứu thực tế (rất dễ kể, nên dùng khi thuyết trình)
- Hạn chế và thảo luận
- Đóng góp và kết luận
- Gợi ý kịch bản thuyết trình + bộ câu hỏi Q&A
- Bảng thuật ngữ

1. Kiến thức nền: BGP và AS — giải thích cho người mới

1.1 AS là gì?

Internet không phải một mạng duy nhất mà là “mạng của các mạng”. Mỗi mạng lớn do một tổ chức quản lý (VNPT, Viettel, Google, Amazon, một trường đại học lớn...) được gọi là một **AS — Autonomous System**, và có một số hiệu riêng gọi là ASN, ví dụ AS16509 là Amazon, AS32934 là Facebook. Hiện có hơn 80.000 AS.

1.2 Prefix là gì?

Prefix (tiền tố) là một dải địa chỉ IP, viết dạng 10.0.0.0/24. Con số sau dấu gạch chéo cho biết dải rộng hay hẹp: số càng nhỏ dải càng rộng. /20 rộng hơn /24. Mỗi AS “sở hữu” và quảng bá ra Internet những prefix của mình.

Ví von dễ nhớ: AS giống như một *tỉnh*, prefix giống như *một dãy số nhà* trong tỉnh đó, còn BGP là *tấm biển chỉ đường* giữa các tỉnh. Tấm biển ghi: “muốn tới dãy số nhà 10.0.0.x thì đi qua tỉnh A, rồi tỉnh B, rồi tới tỉnh V”.

1.3 BGP hoạt động ra sao?

BGP (Border Gateway Protocol) là giao thức để các AS nói cho nhau biết “tôi biết đường tới prefix nào, và đường đó đi qua những AS nào”. Bản tin BGP chủ yếu gồm hai thứ:

- **Prefix** — dải IP đích.
- **AS-PATH** — danh sách các AS phải đi qua, ví dụ AS1 AS2 AS7 nghĩa là từ đây đi qua AS1, AS2 rồi tới AS7 — và AS7 (AS cuối cùng, gọi là **origin AS**) chính là chủ sở hữu prefix.

Khi một AS nhận được nhiều đường đi tới cùng một prefix, nó chọn một đường “tốt nhất” theo thứ tự ưu tiên:

1. Ưu tiên theo **quan hệ kinh doanh**: đường qua *khách hàng* > qua *đối tác ngang hàng (peer)* > qua *nhà cung cấp*. Lý do đơn giản là tiền: đi qua khách hàng thì mình được trả tiền, đi qua nhà cung cấp thì mình phải trả tiền.
2. Nếu quan hệ ngang nhau: chọn **AS-PATH ngắn hơn**.
3. Nếu vẫn ngang nhau: chọn đường của chủ sở hữu thật.

1.4 Lỗ hổng gốc rễ

BGP không xác thực. Khi AS X nói “tôi có đường tới prefix P qua AS-PATH này”, không ai kiểm tra xem X có thật sự có đường đó không, cũng không ai kiểm tra AS-PATH có bịa hay không. Cả Internet chạy trên niềm tin. Đây là gốc rễ của mọi vụ hijacking suốt 25 năm qua.

1.5 Hai khái niệm phụ nhưng hay được hỏi

- **VP (Vantage Point — điểm quan sát):** một số router trên thế giới tự nguyện gửi toàn bộ bảng định tuyến BGP của mình cho các kho dữ liệu công cộng như **RIPE RIS** và **RouteViews**. Nhờ đó nhà nghiên cứu “nhìn thấy” Internet đang định tuyến ra sao. Ares chỉ dùng dữ liệu công khai này, không cần AS nào hợp tác.
- **Luật valley-free:** một AS không nên chuyển tiếp đường đi nhận từ nhà cung cấp/peer sang một nhà cung cấp/peer khác — vì làm thế là gánh lưu lượng không ai trả tiền. Đường đi vi phạm luật này thường là dấu hiệu bất thường (nhưng không phải lúc nào cũng vậy — đây là chỗ khiến nhiều hệ thống cũ báo nhầm).

2. Prefix hijacking: kiểu cũ và kiểu mới

2.1 Origin hijacking (kiểu cũ, Type-0)

Kẻ tấn công H đơn giản tuyên bố: “Prefix 10.0.0.0/20 là của tôi”. Trong khi chủ thật là V. Các AS ở gần H sẽ tin H và gửi lưu lượng nhầm sang H.

Chủ thật V quảng bá:	... -> V	(AS-PATH kết thúc bằng V)
Kẻ xấu H quảng bá:	... -> H	(AS-PATH kết thúc bằng H) <-- MÃU THUẬN!

Vì sao dễ bắt: cùng một prefix mà xuất hiện hai origin AS khác nhau → gọi là xung đột **MOAS** (Multiple Origin AS). Các hệ thống như RPKI-ROV chỉ cần tra sổ đăng ký xem prefix này thuộc AS nào là phát hiện ngay. Các sự cố nổi tiếng như Pakistan chặn YouTube (2008), AS 7007 (1997) đều thuộc loại này, và thường do cấu hình sai chứ không phải cố ý.

2.2 Path hijacking (kiểu mới, Type-N)

Kẻ tấn công H tinh ranh hơn: nó vẫn để tên V ở cuối AS-PATH, chỉ thêm chính mình vào trước. Nghĩa là nó nói: “Tôi không phải chủ prefix này, V mới là chủ — nhưng tôi có đường đi tới V, và đường của tôi ngắn lắm.”

Chủ thật V quảng bá:	... -> V	
Kẻ xấu H quảng bá:	... -> H -> V	<-- KHÔNG mâu thuẫn origin!
	~~~~~	
	liên kết H-V này là BỊA (fake link)	

**Vì sao khó bắt:** không có MOAS, RPKI-ROV hoàn toàn vô dụng vì origin AS vẫn đúng là V. Chỉ có thể nghi ngờ nếu biết rằng H và V thực ra chưa từng kết nối với nhau. Chữ N trong “Type-N” là độ dài đoạn đường mà kẻ tấn công bịa ra: Type-1 là bịa 1 chặng, Type-2 là bịa 2 chặng, v.v.

2.3 Defcon hijacking (Type-U) — biến thể khó nhất

Được trình diễn tại hội nghị Defcon 2008. Kẻ tấn công **không bịa liên kết nào cả**: nó lấy nguyên một đường đi **có thật** tới nạn nhân rồi gắn đường đó vào bản tin của mình. Mọi liên kết trong AS-PATH đều tồn tại thật trong Internet, nên mọi hệ thống “dò liên kết giả” đều mù hoàn toàn.

Điểm yếu của kiểu này: đường đi trở nên dài hơn nên khó cạnh tranh, vì vậy nó thường được dùng kèm **sub-prefix hijacking** (xem mục 3) để thắng chắc chắn.

Ba câu nói gọn để nhớ ba kiểu tấn công:

Type-0: “Nhà này là của tôi.” (giả mạo chủ sở hữu)

Type-N: “Nhà đó của anh V, nhưng tôi có lối tắt dẫn tới anh ấy.” (bịa lối tắt)

Type-U: “Nhà đó của anh V, tôi đi theo đúng con đường thật mà ai cũng biết.” (mượn đường thật — không bịa gì)

3. Phân loại tấn công (bảng quan trọng cần thuộc)

Bài báo dùng cách phân loại của Sermpezis và cộng sự, gồm **3 trục độc lập**. Một cuộc tấn công cụ thể là tổ hợp của cả ba trục — đây là lý do bảng so sánh trong bài có tới 12 dòng.

Trục phân loại	Kiểu	Giải thích
Theo AS-PATH (bịa đường như thế nào)	Type-0 (origin hijacking)	Kẻ tấn công tự nhận là chủ prefix.
	Type-N, N≥1 (path hijacking)	Bịa một đoạn đường dài N chặng dẫn tới nạn nhân.
	Type-U (Defcon hijacking)	Gắn thêm một đường đi <b>có thật</b> tới nạn nhân, không bịa liên kết nào.
Theo prefix bị ảnh hưởng	Exact prefix hijacking	Quảng bá <b>đúng</b> dải IP của nạn nhân → phải cạnh tranh sòng phẳng, chỉ thắng ở một phần Internet.
	Sub-prefix hijacking	Quảng bá một <b>dải con</b> (vd. nạn nhân có /20, kẻ tấn công quảng bá /21). Router luôn ưu tiên dải hẹp nhất → <b>thắng gần như tuyệt đối</b> , nguy hiểm hơn nhiều.
Theo cách xử lý lưu lượng	BH — Blackholing	Vứt bỏ lưu lượng → nạn nhân mất kết nối (tấn công từ chối dịch vụ).
	IM — Imposture	Giả mạo máy chủ nạn nhân để lừa đảo (phishing).
	MM — Man-in-the-Middle	Nghe lén rồi <b>vẫn chuyển tiếp</b> lưu lượng về đúng nạn nhân → nạn nhân không hề hay biết. Kiểu này qua mặt mọi hệ thống kiểm tra bằng ping/traceroute vì mạng vẫn “thông”.

Điểm nhấn khi thuyết trình: tổ hợp nguy hiểm nhất là **Sub-prefix + Type-U + MM**: dải con nên thắng tuyệt đối, đường đi toàn liên kết thật nên không lộ, lưu lượng vẫn được chuyển về nạn nhân nên không ai biết bị nghe lén. Trong bảng so sánh của bài báo, **chỉ Ares và Artemis** bắt được tổ hợp này — mà Artemis thì chỉ bảo vệ được chính AS đã cài nó.

Thực tế: tấn công để ăn cắp tiền số

Bài báo nhắc tới các vụ có thật: hijack Amazon Route 53 để chiếm ví Ethereum (2018), vụ KLAYswap (2022), vụ khiến người giữ tiền số mất 235.000 USD (2022), vụ trộm 83.000 USD Bitcoin (2014). Đây là lý do path hijacking không còn là chuyện học thuật.

4. Vì sao các hệ thống cũ thất bại

Nhóm phương pháp	Đại diện	Điểm mù
Kiểm tra chủ sở hữu	RPKI-ROV, PHAS, Themis	Chỉ bắt origin hijacking. Với path hijacking thì origin vẫn đúng → <b>hoàn toàn mù</b> .
Dựa trên liên kết giả (link-based)	Metis (2023), DFOH (2024)	Bắt khá tốt Type-N, nhưng <b>bỏ tay hoàn toàn với Type-U</b> vì Defcon không tạo liên kết mới nào. Metis còn mặc định <b>tin mọi liên kết có Tier-1</b> → recall bằng 0% khi Tier-1 liên quan.
Dựa trên vi phạm valley-free	Argus, Fingerprints, HEAP	Trong thực tế có <b>rất nhiều</b> đường đi hợp lệ nhưng vi phạm valley-free → <b>báo nhầm nhiều</b> (FPR cao).
Dựa trên mặt dữ liệu (ping/traceroute)	iSPY, Argus, HEAP	Không bắt được <b>MM</b> (lưu lượng vẫn tới đích nên mạng vẫn “thông”), không bắt được <b>IM</b> trong nhiều trường hợp; lại không đưa ra được thông tin mặt điều khiển nên người vận hành rất khó xác minh.
Tự bảo vệ bằng thông tin nội bộ	Artemis (2018)	Bắt được mọi kiểu, <b>nhưng</b> cần AS tự khai báo prefix và chính sách bí mật của mình, và <b>chỉ bảo vệ chính AS đó</b> → không giám sát được toàn Internet.

Bài báo tóm gọn kết luận: “Hiện chưa có hệ thống nào phát hiện được path hijacking một cách toàn diện, khiến các vụ tấn công tiềm ẩn trôi qua mà không bị phát hiện.” Đó chính là khoảng trống Ares lấp vào.

## 5. Ý tưởng cốt lõi: OPRT và quan sát của nhóm tác giả

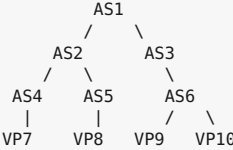
### 5.1 OPRT là gì?

Với một prefix P, ta lấy đường đi tốt nhất từ **mọi VP** tới P. Gộp tất cả các đường đó lại, vì chúng đều kết thúc ở cùng origin AS, ta được một **cây** có gốc là origin AS. Cây đó gọi là **OPRT — Observed Prefix’s Routing Tree** (cây định tuyến quan sát được của prefix).

Các đường đi quan sát được tới prefix 10.0.0.0/24 (gốc = AS1):

VP7 -> AS4 -> AS2 -> AS1  
VP8 -> AS5 -> AS2 -> AS1  
VP9 -> AS6 -> AS3 -> AS1  
VP10 -> AS6 -> AS3 -> AS1

Gộp lại thành cây:



Lưu ý thuật ngữ: PRT (Prefix’s Routing Tree) là cây **lý tưởng** gộp đường đi từ **mọi** AS trên Internet — không thể lấy được trong thực tế. OPRT là phiên bản **quan sát được**, chỉ gộp đường đi từ tập VP mà ta có. Đây là lý do có chữ “Observed”.

### 5.2 Hai quan sát then chốt (đây là phần “vision” của bài báo)

**Quan sát 1 — Mỗi AS chỉ có vài dạng OPRT.** Một AS thường quảng bá các prefix của mình **theo lô**, theo cùng một chính sách định tuyến (để điều phối lưu lượng). Các prefix cùng chính sách sẽ lan truyền theo đường giống hệt nhau → **có cùng dạng cây OPRT**, gọi là các prefix “tương đương OPRT”. Đo đạc thực tế cho thấy:

- **Hơn 80% AS có dưới 10 dạng cây OPRT**, dù có thể sở hữu hàng trăm prefix.
- AS Tier-1 và AS nội dung (Google, Amazon...) có nhiều dạng cây hơn do chính sách phức tạp và nhiều loại dịch vụ. Ví dụ AS16509 (Amazon) có hơn 800 dạng cây nhưng đa số chỉ ứng với dưới 10 prefix.

**Quan sát 2 — Hijacking luôn tạo ra một OPRT mới.** Giả sử hai prefix 10.0.0.0/24 và 10.0.1.0/24 của cùng một AS đang dùng chung một cây OPRT. Khi kẻ tấn công AS11 hijack riêng 10.0.1.0/24, đường đi tới prefix này thay đổi → nó tách ra và hình thành **một cây OPRT mới, khác hẳn cây bình thường**.

**Suy ra cơ chế phát hiện:** chỉ cần theo dõi **số lượng cây OPRT (chính xác hơn: số cụm OPRT) của mỗi AS**. Số cụm bỗng tăng lên = có prefix nào đó đang bị lôi đi theo hướng bất thường = nghi bị hijack.

**Vì sao cách này bao phủ được mọi kiểu path hijacking:** dù kẻ tấn công bịa liên kết (Type-N) hay mượn đường thật (Type-U), dù hijack exact hay sub-prefix, chỉ cần tấn công **có hiệu lực** (tức là kéo được lưu lượng về) thì đường đi **bắt buộc** phải thay đổi — mà đường đi thay đổi thì cây thay đổi. Đây là điểm mạnh căn bản: Ares không đi tìm “dấu vết đặc trưng” của từng kiểu tấn công, nó bắt **hệ quả chung** mà mọi kiểu tấn công đều phải để lại.

### 5.3 Liệu kẻ tấn công có né được không?

Nhóm tác giả chỉ ra chỉ có hai cách né, và cả hai đều vô nghĩa:

1. **Hijack đồng thời toàn bộ các prefix tương đương OPRT** — khi đó cây “cũ” biến mất hoàn toàn, số cụm không tăng. Nhưng làm vậy gây gián đoạn lưu lượng rất lớn, nạn nhân phát hiện ngay lập tức.
2. **Kẻ tấn công là nhà cung cấp duy nhất của nạn nhân** — nhưng khi đó nó đã nắm toàn bộ lưu lượng rồi, hijack để làm

gì?

6. Bối cảnh thách thức kỹ thuật

Ý tưởng “đếm số cây” nghe đơn giản, nhưng đem ra thực tế thì vỡ ngay vì 4 vấn đề. Mỗi vấn đề dẫn tới một thành phần trong thiết kế — nên đây là bản đồ để hiểu Phần 7.

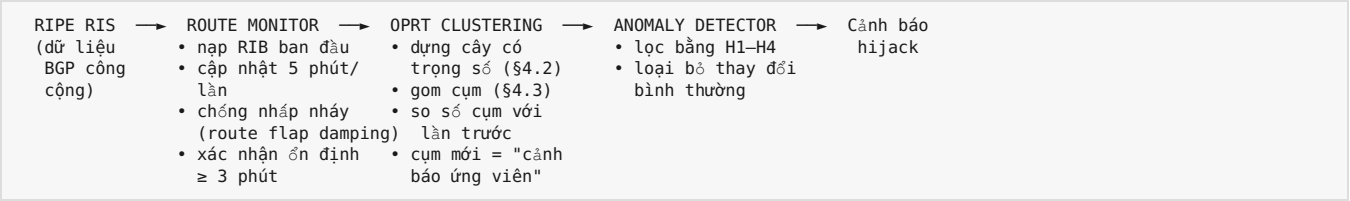
Thách thức	Vì sao xảy ra	Giải pháp của Ares
1. Có nhiều cây “hiếm” và không ổn định (niche & unstable OPRT)	Một số prefix có cây hơi khác cây chính do chính sách khác chút hoặc do BGP chưa hội tụ xong. Chúng khiến số cây nhấp nháy liên tục → báo động giả liên miên.	<b>Gom cụm (clustering)</b> : gộp cây hiếm vào cây chính nếu đủ giống nhau, rồi chỉ theo dõi số cụm chứ không theo dõi số cây. Gom cụm còn có tác dụng phụ rất hay: khiến kẻ tấn công khó né hơn, vì muốn né phải hijack cả cụm.
2. Khó phân biệt cây bị hijack với cây bình thường	Gom cụm có thể vô tình nhét cây bị hijack vào cụm bình thường → bỏ sót.	<b>Khoảng cách chỉnh sửa có trọng số</b> : gán trọng số cao cho các liên kết đáng ngờ và các liên kết quan trọng, để “khuếch đại” khác biệt của cây bị hijack.
3. Theo dõi tất cả OPRT rất tốn kém	Có AS có hơn 1.000 cây khác nhau; tính khoảng cách đôi một giữa chúng thì bùng nổ tổ hợp.	Thuật toán gom cụm <b>hai pha dùng băm SHA-256</b> + chia cụm chính/cụm phụ + <b>cập nhật gia tăng</b> thay vì gom lại từ đầu.
4. Sự kiện bình thường cũng làm đổi số cụm	Đổi chính sách định tuyến, thêm đường dự phòng, đứt cáp... đều tạo cây mới → báo nhầm, khiến người vận hành mất công điều tra vô ích.	<b>4 luật lọc kinh nghiệm H1-H4</b> trong bộ phát hiện bất thường.

7. Thiết kế hệ thống Ares

7.1 Nguyên tắc thiết kế (6 mục tiêu tác giả tự đặt ra)

- **Chính xác** — FPR thấp, recall cao.
- **Thời gian thực** — phát hiện ngay khi đang xảy ra.
- **Toàn diện** — bao phủ mọi kiểu path hijacking.
- **Phạm vi toàn Internet** — giám sát mọi AS, không cần AS hợp tác.
- **Cung cấp thông tin mặt điều khiển** — chỉ rõ ai là kẻ tấn công, liên kết nào đáng ngờ, kéo dài bao lâu, để người vận hành xác minh được.
- **Nhẹ** — dễ triển khai, ít tài nguyên.

7.2 Luồng hoạt động tổng thể



7.3 Khối 1 — Route Monitor (bộ giám sát định tuyến)

Liên tục thu dữ liệu BGP từ RIPE RIS qua công cụ BGPStream. Cứ 5 phút gộp thành một ảnh chụp và đẩy sang khối gom cụm. Hai cơ chế chống nhiễu:

- **Route Flap Damping** (theo chuẩn IETF RFC 2439): prefix nào bị quảng bá rồi rút liên tục thì bị “phạt” và loại khỏi quá trình gom cụm.
- **Xác nhận ổn định**: chỉ nhận đường đi nào giữ nguyên **quá 3 phút**, vì nghiên cứu cho thấy BGP thường hội tụ trong vòng 3 phút. Tránh nhầm giai đoạn hội tụ với tấn công.

7.4 Khối 2 — Weighted Edit Distance (trái tim thuật toán)

**Edit distance là gì?** Là “chi phí biến cây A thành cây B” bằng các thao tác thêm/xóa cạnh. Ví dụ: muốn biến cây A thành cây B phải xóa cạnh (7,8), thêm cạnh (4,8), (7,9), (7,10) → khoảng cách = tổng trọng số của 4 cạnh đó. Càng nhỏ thì hai cây càng giống nhau.

Công thức tổng quát: khoảng cách giữa hai cây = tổng trọng số các cạnh chỉ có ở A + tổng trọng số các cạnh chỉ có ở B + tổng chênh lệch trọng số của các cạnh chung.

**Vấn đề: không phải cạnh nào cũng quan trọng như nhau.** Nếu coi mọi cạnh bằng nhau, một thay đổi vụn vặt ở rìa cây có thể bị coi ngang một vụ hijack. Vì vậy Ares gán trọng số theo 4 yếu tố:

Yếu tố	Quy tắc	Trực giác
(a) Tần suất liên kết <code>W_freq</code>	Liên kết xuất hiện <b>càng nhiều</b> trong bảng định tuyến thì trọng số <b>càng thấp</b> . Công thức: $W_freq = C1 / (1 + \text{Cnt}(A,B))$	Liên kết quen thuộc thì đáng tin. Liên kết <b>chưa từng thấy</b> thì rất đáng ngờ — và path hijacking hầu như luôn sinh ra liên kết lạ.
(b) Khoảng cách địa lý <code>W_geo</code>	Hai AS càng xa nhau về địa lý, trọng số càng cao. Dùng hàm <i>trung bình điều hòa</i> $C2 \cdot D / (C2 + D)$ với $C2 = 1000$ để giá trị tăng mượt và không bùng nổ.	Một liên kết trực tiếp giữa một AS ở Việt Nam và một AS ở Brazil là chuyện lạ — đáng nghi.
(c) Hệ số điều chỉnh theo hạng AS <code>Adj</code>	$Adj = (R_A \times R_B) / N^2$ , với R là thứ hạng ASRank (hạng số nhỏ = AS lớn). AS càng lớn thì Adj càng nhỏ → kéo trọng số xuống.	Tier-1 vốn có điểm hiện diện ở nhiều nước, liên kết xuyên lục địa của họ là bình thường — không được phạt oan.
(d) Vị trí trong cây & số VP quan sát	$W = v \times W_feat \times (1 - \min(d / (2 \cdot L_avg), 1))$ , với v = số VP nhìn thấy cạnh, d = khoảng cách từ cạnh tới gốc.	Cạnh <b>gần gốc</b> và được <b>nhiều VP</b> nhìn thấy thì ảnh hưởng tới nhiều người hơn → quan trọng hơn. Một thay đổi ở rìa cây mà chỉ 1 VP thấy thì chỉ là nhiễu.

Trọng số tổng hợp:  $W_feat = w1 \cdot W_freq + w2 \cdot W_geo$  với  $w1 + w2 = 1$ . Qua thử nghiệm trên 6 sự kiện lịch sử, tác giả chọn **w1 = 0,6 và w2 = 0,4**: đây là điểm nhỏ nhất vẫn bắt đủ mọi sự kiện lịch sử, trong khi tăng w1 thêm nữa chỉ làm số cảnh báo tăng lên (từ 108 lên 128 cảnh báo) mà không bắt thêm được gì.

**Tóm một câu:** hai loại cạnh được gán trọng số cao — **cạnh quan trọng** (gần gốc, nhiều VP thấy) và **cạnh đáng ngờ** (lạ, hoặc nối hai AS cách xa nhau về địa lý). Nhờ vậy khoảng cách vừa phản ánh khác biệt *cấu trúc*, vừa phản ánh mức độ *đáng ngờ*.

7.5 Khối 3 — Gom cụm (Clustering), 4 bước

- 1. **Băm cấu trúc:** băm tập cạnh của mỗi cây bằng SHA-256. Hai cây giống hệt nhau sẽ có cùng mã băm → gộp ngay lập tức mà không cần tính toán gì. Đây là mẹo tăng tốc quan trọng nhất.
- 2. **Chia cụm chính / cụm phụ:** cụm nào ứng với **hơn 10 prefix** thì là **cụm chính** (mainstream), còn lại là **cụm phụ** (subcluster). Ngưỡng 10 đến từ quan sát ở Phần 5: dưới 20% dạng cây được chia sẽ bởi hơn 10 prefix.
- 3. **Gộp cụm phụ vào cụm chính:** tính khoảng cách chỉnh sửa có trọng số; nhỏ hơn ngưỡng thì gộp.
- 4. **Gộp các cụm phụ còn lại với nhau:** so từng đôi một; vì lúc này một cụm phụ có thể chứa nhiều cây, tác giả tính khoảng cách giữa **mọi cặp cây** và lấy **giá trị lớn nhất** (cách gộp thận trọng, tránh gộp bừa).

**Cập nhật gia tăng (Update Clustering):** sau lần gom cụm đầy đủ đầu tiên, các lần sau Ares **không** gom lại từ đầu. Nó chỉ lấy những cây vừa thay đổi và thử gộp vào các cụm đã có. Một chi tiết tinh tế: kể cả khi một cụm trở nên rỗng, Ares **vẫn giữ lại cụm rỗng đó** — vì đôi khi AS đổi chính sách cho cả nhóm prefix cùng lúc, giữ lại giúp tránh hiểu nhầm là “xuất hiện cụm mới”.

7.6 Khối 4 — Anomaly Detector và 4 luật lọc H1-H4

Mỗi cụm mới xuất hiện gọi là **“cảnh báo ứng viên”**. Nếu **bất kỳ** luật nào dưới đây bắt được, nó bị xếp là thay đổi bình thường; nếu vượt qua cả 4 luật thì mới thành **cảnh báo hijack**.

Luật	Tên	Nội dung và lý do
H1	Khoảng cách chỉnh sửa <b>một phần</b>	Nếu cây mới chỉ là <b>tập con</b> của cây cũ — tức không có đường đi nào mới xuất hiện, chỉ là một số VP ngừng quan sát được — thì gần như chắc chắn không phải hijack, vì <b>hijack luôn mang theo đường đi mới chưa từng thấy</b> . Do đó Ares chỉ tính khoảng cách trên <b>các liên kết mới xuất hiện</b> . Xử lý các trường hợp BGP chưa hội tụ hoặc lọc đường.
H2	Kích thước cụm mới	Nếu cụm mới chứa <b>từ 10 prefix trở lên</b> → coi là thay đổi bình thường. Lý do: hijack thật thường chỉ nhắm vài prefix (hijack hàng loạt sẽ gây rối loạn và lộ ngay), còn việc đổi chính sách định tuyến thì mới làm hàng loạt prefix đổi đường cùng lúc.
H3	Thông tin lịch sử	Ares lưu một cơ sở dữ liệu các <b>cấu trúc cây ổn định, bình thường</b> đã từng thấy. Nếu cụm mới gần giống một cấu trúc đã lưu → hợp lệ. Xử lý trường hợp AS có vài prefix “đặc biệt” mà cây luôn khác người, cứ đổi là báo nhầm.
H4	Quan hệ kinh doanh đã biết	Lấy các liên kết <b>trọng số cao</b> trong cụm mới ra xét: liên kết đó (1) <b>chưa từng tồn tại</b> theo bộ dữ liệu quan hệ kinh doanh của CAIDA, hoặc (2) gây <b>vi phạm valley-free</b> → đánh dấu bất thường. Ngược lại thì coi là bình thường. <b>Đây là luật lọc hiệu quả nhất</b> theo đánh giá thực nghiệm.

Phân vai ngắn gọn: H1 chống nhiễu do BGP hội tụ · H2 và H4 nắm bắt đặc trưng điển hình của hijack · H3 dùng ngữ cảnh lịch sử. Bốn luật bổ sung cho nhau chứ không trùng lặp.

7.7 Ngưỡng gộp cụm được chọn thế nào?

Ngưỡng không do người đặt tay mà được tính tự động: chạy thử trên dữ liệu ngày hôm trước, ghi lại mọi khoảng cách chỉnh

sửa nhỏ nhất mỗi lần thử gộp cụm, rồi tìm **điểm gãy (knee point)** của phân bố bằng thư viện *kneed*. Vì điểm gãy nhạy với nhiễu, tác giả cộng thêm **4 lần MAD** (Median Absolute Deviation — độ lệch tuyệt đối trung vị) để ổn định. Do Internet luôn biến động, ngưỡng nên tính lại định kỳ, khoảng **mỗi tháng một lần**.

## 8. Thực nghiệm và kết quả

### 8.1 Thí nghiệm 1 — 12 sự kiện tấn công có thật trong lịch sử

**Dữ liệu chuẩn:** 12 sự kiện path hijacking có thật, lấy từ bộ dữ liệu của Cho và cộng sự cộng thêm 2 sự kiện năm 2022 (Zayo và Amazon), trong đó có một vụ Defcon. Cách làm: nạp bảng định tuyến gần nhất trước sự kiện làm ảnh chụp ban đầu, rồi đổ toàn bộ bản tin BGP vào Ares, xem nó có báo đúng prefix và đúng kẻ tấn công không.

Chỉ số	Kết quả
Số sự kiện phát hiện được	<b>12/12</b> , mỗi vụ trong vòng <b>5 phút</b> kể từ khi xảy ra
Số cảnh báo trung bình	<b>1,49 cảnh báo/giờ</b> (không tính sự kiện enzu_1)
Tỷ lệ bản tin BGP / một cảnh báo	Từ ~8.000 tới ~845.000 bản tin mới sinh 1 cảnh báo → FPR cực thấp
Trường hợp ngoại lệ enzu_1	288 cảnh báo, nhưng <b>257 được xác nhận là đúng</b> — vì đây thực ra là vụ rò rỉ định tuyến quy mô lớn của Enzu Inc.

**Luật nào lọc được nhiều nhất? H4** (quan hệ kinh doanh) hiệu quả nhất, lọc được nhiều cảnh báo giả nhất — vì nguyên nhân gây nhiễu phổ biến nhất trên Internet là các AS đối ưu tiên định tuyến làm lộ ra những liên kết vốn có nhưng ít khi thấy. **H3** đứng thứ hai. H1 và H2 giúp ít hơn vì tình huống mục tiêu của chúng (BGP chưa hội tụ, đổi chính sách hàng loạt) ít gặp hơn.

### 8.2 Thí nghiệm 2 — Mô phỏng quy mô lớn

**Vì sao phải mô phỏng?** Sự kiện hijacking có thật được ghi nhận đầy đủ là **cực hiếm** — 12 sự kiện không đủ để đánh giá 16 loại tổ hợp tấn công. Đây chính là **đóng góp thứ hai** của bài báo: một phương pháp mô phỏng lai, **ghép dữ liệu BGP thật với các bản tin BGP được chế tạo**.

**Cách làm:** chia AS thành 4 loại (Tier-1, Content, Enterprise, Transit/Access) theo bảng phân loại của CAIDA →  $4 \times 4 = 16$  **tổ hợp (kẻ tấn công, nạn nhân)**. Mỗi tổ hợp lấy khoảng 100 cặp AS, mô phỏng Type-1/2/3 và Type-U, cả exact lẫn sub-prefix → tổng **1.706 sự kiện dương**. Đồng thời lấy mẫu ngẫu nhiên **1.706 thay đổi định tuyến có thật** trong 2 giờ ngày 1/10/2024 làm **sự kiện âm** để đo FPR.

Phương pháp	Recall (Tier-1 & Content, kẻ tấn công không phải Tier-1)	FPR	Điểm mù lớn nhất
<b>Ares</b>	<b>97,2% exact / 99,3% sub-prefix; bắt 100% Type-U</b>	<b>1,06%</b>	Kẻ tấn công là Tier-1 (xem Phần 10)
Metis (2023)	0% khi có Tier-1 tham gia; 36-52% với Content; gần 0% với Type-U	0,53%	Tin mọi liên kết Tier-1; mù Type-U
DFOH (2024)	~60,4% / 65,2% cho Type-1/2/3; <b>0% cho Type-U</b>	0%	Chỉ xét liên kết mới → mù hoàn toàn Type-U; recall dao động mạnh 22-87% tùy kịch bản
BEAM (bản tinh chỉnh)	41,7% exact / 77,7% sub-prefix	4,75%	Ngưỡng tự sinh chạy rất kém; recall exact tụt dần khi đường bìa dài ra

Lưu ý khi đọc bảng: DFOH có FPR = 0% trông đẹp, nhưng đi kèm recall thấp và mù hoàn toàn Type-U — tức là nó ít báo nhầm vì nó **ít báo**. Ares đánh đổi 1,06% FPR để lấy độ phủ toàn diện, và 1,06% này vẫn thấp hơn BEAM.

### 8.3 Thí nghiệm 3 — Hiệu năng

Chỉ tiêu	Ares	Metis	DFOH	BEAM
Thời gian xử lý 5 phút dữ liệu	<b>6,33 s</b>	12,5 s	16,1 s	23,9 s
Bộ nhớ	50 GB	20 GB	<4,5 GB	<5 GB
Dung lượng đĩa	<b>2 GB</b>	21 GB	>166 GB	~4 GB
Công việc chuẩn bị	<b>&lt;1 giờ tiền xử lý + 1-2 giờ tính ngưỡng/tháng</b>	7-9 giờ huấn luyện/tháng	2-3 giờ bảo trì CSDL/ngày	10-11 giờ huấn luyện/tháng

Ares nhanh nhất và cần chuẩn bị ít nhất, đổi lại tốn RAM nhiều hơn. Vì 6,33 giây << 5 phút nên Ares thừa sức chạy thời gian thực.

## 8.4 Thí nghiệm 4 — Triển khai thật 1 tháng

Chạy trên dữ liệu thật từ bộ thu rrc03 của RIPE RIS suốt tháng 10/2024, xử lý **1.487.907.824 bản tin BGP** (gần 1,5 tỷ).

- **2,31 cảnh báo/giờ** trung bình — so với **11,36** của DFOH cùng kỳ. Đây là con số then chốt về tính thực dụng: một người vận hành hoàn toàn kiểm tra xuế.
- Tổng 1.666 cảnh báo, phân tích thủ công toàn bộ: **751/1.182 là cảnh báo đúng** → **precision 63,0%** (484 cảnh báo bị loại khỏi thống kê vì không đủ bằng chứng kết luận hoặc do AS thử nghiệm).
- Phân loại cảnh báo: 553 là dịch vụ chống DDoS/bảo vệ an ninh, 161 là rò rỉ định tuyến, 148 do yếu tố ngoại cảnh (dữ liệu quan hệ kinh doanh sai), 293 là liên kết mới/dự phòng, 17 do cấu hình sai, 20 là nghi hijack thật.

Tác giả thừa nhận thẳng thắn: vì số vụ hijack thật **cực ít** so với số thay đổi định tuyến hợp lệ (mất cân bằng lớp nghiêm trọng), precision của mọi hệ thống loại này về bản chất đều bị giới hạn. 63% đã là con số rất tốt.

## 9. Bốn ca nghiên cứu thực tế (nên dùng khi thuyết trình)

### Ca 1 — Facebook, 22/3/2011: path hijacking điển hình

Prefix 69.171.255.0/24 của Facebook (AS32934) đổi đường từ VP-2914-32934 thành VP-4134-9318-32934 ở 2 VP. Cấu trúc cây thay đổi rất ít, **nhưng** Ares vẫn báo động vì liên kết (9318, 32934) bất thường. Phân tích cho thấy AS9318 nhiều khả năng đã thao túng thuộc tính prepend của AS32934 để hút lưu lượng.

**Ý nghĩa:** chứng minh cơ chế trọng số hoạt động — thay đổi cấu trúc nhỏ nhưng liên kết đáng ngờ vẫn đủ kéo khoảng cách lên.

### Ca 2 — Defcon 2008: kiểu tấn công khó nhất

Mục tiêu là Sparkplug Las Vegas (AS20195), vốn chỉ có **một** nhà cung cấp duy nhất là AS23005. Bình thường mọi đường tới AS20195 đều kết thúc bằng 23005-20195. Trong lúc tấn công, **tất cả** VP thấy đường đổi thành 26627-4436-22822-23005-20195. Đặc biệt: **mọi liên kết trong đoạn bịa đều tồn tại thật** → mọi hệ thống dò liên kết giả đều mù.

Ares bắt được vì hai lý do: (1) các liên kết (26627,4436) và (4436,22822) ảnh hưởng tới **toàn bộ** VP nên được gán trọng số rất cao; (2) đường đi mới gây vi phạm valley-free.

**Ý nghĩa:** đây là bằng chứng mạnh nhất cho tính “toàn diện” — Metis và DFOH đều có recall 0% với kiểu này.

### Ca 3 — Enzu 2015: rò rỉ định tuyến, không phải hijack

Ares phát hiện mẫu lan truyền bất thường 40633-18978-6939. Điều tra cho thấy đây không phải tấn công mà là Enzu Inc. (AS18978) **vô tình rò rỉ** các sub-prefix do bộ tối ưu BGP tự sinh ra sang sàn trao đổi Internet Los Angeles (AS40633).

**Ý nghĩa:** Ares không chỉ bắt hijack mà còn phát hiện được các bất thường định tuyến khác — một điểm cộng ngoài dự kiến.

### Ca 4 — StormWall, 10/2024: “cảnh báo đúng nhưng không phải tấn công”

Lưu lượng tới Kalaam-Telecom (AS39273) thỉnh thoảng đi qua STORMWALL-AS (AS59796) — một AS không có trong cây định tuyến thông thường và không có quan hệ kinh doanh ghi nhận. Điều tra cho thấy StormWall là **dịch vụ chống DDoS**: họ cố ý quảng bá prefix của khách hàng để hút lưu lượng về lọc sạch rồi mới chuyển tiếp.

**Ý nghĩa:** về mặt kỹ thuật đây **đúng** là hành vi hijack, chỉ khác ở chỗ được khách hàng đồng ý. Tác giả xếp nó là “đúng” và đề xuất giải pháp đơn giản: lập danh sách trắng các nhà cung cấp dịch vụ chống DDoS. Đây là một ví dụ hay để nói về ranh giới giữa “bất thường” và “độc hại”.

## 10. Hạn chế và thảo luận

Hạn chế	Giải thích và phản biện của tác giả
<b>Kẻ tấn công là Tier-1</b> thì recall thấp (có kịch bản chỉ 20,7%)	Vì Tier-1 cung cấp dịch vụ chuyển tiếp cho cả thế giới nên có sẵn vô số đường đi thật, dễ dàng bị đường mà không tạo liên kết lạ. Phản biện: (1) Tier-1 có hạ tầng an ninh tốt, rất khó bị chiếm quyền; (2) Tier-1 <b>không có động cơ</b> hijack vì họ đã xử lý lượng lưu lượng khổng lồ rồi; (3) <b>mọi phương pháp khác cũng thất bại</b> trong kịch bản này (Metis 0%, DFOH 0%).
<b>Bỏ sót các vụ ảnh hưởng nhỏ</b>	Trong các vụ Ares bỏ sót mà kẻ tấn công không phải Tier-1, <b>hơn 80% chỉ ảnh hưởng dưới 5 VP</b> — tức đường bị cạnh tranh yếu, tác động thực tế nhỏ. Tăng số VP sẽ bắt được.
<b>Không bắt được hijack dùng origin AS chưa sử dụng</b>	Nếu kẻ tấn công bị một origin AS chưa từng dùng, Ares không có cây lịch sử để so sánh. Nhưng: nếu prefix đó đang được AS khác dùng thì sinh MOAS (để bắt bằng công cụ khác); nếu prefix chưa bao giờ được dùng thì tác hại gần như bằng 0.
<b>Không xử lý được MOAS</b>	Ares thống kê cây theo <b>từng origin AS riêng biệt</b> nên không phát hiện được bất thường gây MOAS. Tác giả coi đây là phân công lao động hợp lý: RPKI lo MOAS, Ares lo path hijacking; kết hợp cả hai là phủ gần hết.
<b>Phụ thuộc vào vị trí các VP</b>	Như mọi phương pháp dựa trên mặt điều khiển. Lập luận bảo vệ: chỉ cần <b>một</b> VP thấy đổi đường là cây đổi và Ares kích hoạt. Tuy nhiên nếu kẻ tấn công cố tình né hết VP thì mọi hệ thống cùng loại đều thất bại.
<b>Nhằm dịch vụ chống DDoS thành hijack</b>	Thừa nhận có. Giải pháp đề xuất: danh sách trắng.
<b>Ngưỡng cần tính lại định kỳ</b>	Khoảng một tháng một lần, do Internet luôn thay đổi.
<b>Anycast có ảnh hưởng không?</b>	Không. Cây OPRT gắn với <b>origin AS</b> , nên prefix anycast nằm trên nhiều origin AS sẽ được tách thành các cây riêng; tấn công vào origin AS nào thì Ares bắt trong phạm vi origin AS đó.
<b>Kẻ tấn công né bằng cách bật/tắt liên tục?</b>	Sẽ bị cơ chế Route Flap Damping trừng phạt, khiến đường đi bị chặn và cuộc tấn công khó thành công.

## 11. Đóng góp và kết luận

### Ba đóng góp chính (nên nêu rõ khi thuyết trình)

- Hệ thống Ares** — hệ thống phát hiện path hijacking thời gian thực đầu tiên dựa trên cây định tuyến, bắt được **mọi** kiểu path hijacking với recall cao, FPR thấp, hiệu năng tốt; nhờ ba thành phần: khoảng cách chỉnh sửa có trọng số, gom cụm hai pha, và bộ lọc kinh nghiệm.
- Phương pháp mô phỏng lai** — ghép dữ liệu BGP thật với bản tin BGP chế tạo để tạo ra bộ dữ liệu path hijacking quy mô lớn, giải quyết vấn đề **khan hiếm sự kiện thật**. Đây là đóng góp có giá trị độc lập cho cả cộng đồng nghiên cứu.
- Kiểm chứng ba tầng** — sự kiện lịch sử + mô phỏng quy mô lớn + triển khai thật một tháng, kèm mã nguồn và dữ liệu công khai (Zenodo, DOI 10.5281/zenodo.15589806).

### Hướng phát triển

Tác giả dự định tích hợp Ares với ROA/RPKI và các cơ chế bảo mật BGP khác để tạo khung phòng thủ thống nhất, đồng thời đưa Ares vào hệ thống BGPWatch.

#### Câu kết luận một dòng để chốt bài thuyết trình:

Thay vì đuổi theo từng biến thể tấn công mới, Ares chuyển sang bắt cái **hệ quả chung** mà mọi biến thể đều để lại — sự xuất hiện của một cây định tuyến mới lạ — và nhờ đó lần đầu tiên phủ được toàn bộ phổ path hijacking trên quy mô toàn Internet, với chi phí đủ nhẹ để chạy thật.

## 12. Gợi ý kịch bản thuyết trình và bộ câu hỏi Q&A

### 12.1 Kịch bản 15 phút

Phút	Nội dung	Cách nói
0-2	Mở bài bằng câu chuyện	Kể vụ mất 235.000 USD tiền số năm 2022 do BGP hijacking. Đặt câu hỏi: “Vì sao Internet vận hành trên niềm tin?”
2-5	Nền tảng: AS, prefix, BGP	Dùng ví von tình / số nhà / biển chỉ đường. Nhấn mạnh: BGP không xác thực.
5-8	Origin vs Path hijacking	Vẽ hai sơ đồ đơn giản. Nhấn mạnh: path hijacking <b>không</b> gây MOAS → RPKI vô dụng. Nếu thêm Defcon (Type-U) là ca khó nhất.
8-11	<b>Ý tưởng cốt lõi</b> (phần quan trọng nhất)	Vẽ cây OPRT. Nói: “80% AS chỉ có dưới 10 dạng cây; hijack luôn để ra cây mới; vậy cứ đếm số cây.” Đây là chỗ cả lớp phải hiểu.
11-13	Thiết kế Ares	4 khối theo sơ đồ luồng. Giải thích trọng số bằng trực giác (liên kết lạ + liên kết xa + gần gốc + nhiều VP thấy = đáng ngờ). Nêu 4 luật H1-H4 ở mức khái niệm.
13-15	Kết quả và kết luận	Ba con số: <b>12/12, 97,2%/99,3% với FPR 1,06%, 2,31 cảnh báo/giờ</b> . Kể nhanh ca Defcon để minh họa tính toàn diện. Chốt bằng câu kết ở Phần 11.

## 12.2 Câu hỏi có thể bị hỏi và cách trả lời

### Hỏi: Vì sao không dùng RPKI là xong?

Đáp: RPKI xác thực **ai là chủ prefix**. Trong path hijacking, kẻ tấn công vẫn ghi đúng chủ sở hữu ở cuối AS-PATH, nó chỉ bịa đoạn đường dẫn tới chủ. Muốn chống triệt để phải dùng BGPsec (ký từng chặng), nhưng BGPsec gần như chưa được triển khai vì quá tốn kém và cần cả thế giới cùng làm.

### Hỏi: Ares khác Metis/DFOH ở đâu về bản chất?

Đáp: Metis và DFOH đi tìm **liên kết giả** — tức dấu vết của *một kiểu* tấn công. Ares đo **sự thay đổi cấu trúc cây định tuyến** — tức hệ quả mà *mọi* kiểu tấn công đều phải gây ra. Vì vậy khi kẻ tấn công dùng Defcon (không tạo liên kết giả), hai hệ kia về 0% còn Ares vẫn bắt được.

### Hỏi: FPR 1,06% nghe nhỏ, nhưng quy ra thực tế là bao nhiêu?

Đáp: Triển khai thật cho ra 2,31 cảnh báo/giờ trên toàn Internet, tức khoảng 55 cảnh báo/ngày — một người trực hoàn toàn xem xuể. DFOH cùng kỳ là 11,36 cảnh báo/giờ.

### Hỏi: Precision chỉ 63% thì có dùng được không?

Đáp: Được, vì (1) khối lượng tuyệt đối rất nhỏ; (2) bài toán này mất cân bằng lớp cực nặng — hijack thật cực hiếm so với thay đổi định tuyến hợp lệ, nên precision cao là bất khả thi về mặt lý thuyết; (3) nhiều “cảnh báo sai” thật ra là rò rỉ định tuyến hoặc cấu hình sai — vẫn là thứ người vận hành muốn biết.

### Hỏi: Vì sao chọn ngưỡng 10 prefix?

Đáp: Từ đo đạc thực tế — dưới 20% dạng cây được chia sẻ bởi hơn 10 prefix. Kết hợp với nhận định rằng hijack thật thường chỉ nhắm vài prefix, còn thay đổi chính sách mới tác động hàng loạt.

### Hỏi: Nếu kẻ tấn công biết Ares hoạt động thế nào thì có né được không?

Đáp: Bài báo bàn ba cách né và đều bác bỏ: hijack cả cụm (gây gián đoạn lớn, lộ ngay), bật/tắt liên tục (bị Route Flap Damping chặn), né hết VP (khả thi về lý thuyết nhưng khi đó **mọi** hệ thống dựa trên mặt điều khiển đều thất bại, không riêng Ares).

### Hỏi: Điểm yếu lớn nhất của bài báo là gì? (câu hỏi phản biện hay gặp)

Đáp: Ba điểm. (1) Recall sụt mạnh khi kẻ tấn công là Tier-1 — tác giả biện hộ hợp lý nhưng vẫn là điểm mù thật. (2) Đánh giá chủ yếu dựa trên **mô phỏng** do thiếu sự kiện thật, mà mô phỏng luôn có giả định đơn giản hóa. (3) Việc xác nhận 1.666 cảnh báo là **thủ công, do chính tác giả làm** — mang tính chủ quan. Ngoài ra Ares tốn 50 GB RAM, cao nhất trong bốn phương pháp.

## 13. Bảng thuật ngữ

Thuật ngữ	Tiếng Việt	Ý nghĩa
<b>BGP</b> (Border Gateway Protocol)	Giao thức cổng biên	Giao thức định tuyến giữa các AS trên Internet. Không có cơ chế xác thực.
<b>AS</b> (Autonomous System)	Hệ thống tự trị	Một mạng lớn do một tổ chức quản lý, có số hiệu riêng (ASN).
<b>Prefix</b>	Tiền tố / dải địa chỉ IP	Ví dụ 10.0.0.0/24. Số sau dấu / càng lớn thì dải càng hẹp.
<b>AS-PATH</b>	Đường đi qua các AS	Danh sách AS phải đi qua để tới prefix. AS cuối cùng là origin AS.
<b>Origin AS</b>	AS gốc	AS sở hữu và quảng bá prefix.
<b>MOAS</b>	Đa AS gốc	Một prefix xuất hiện với hai origin AS khác nhau — dấu hiệu origin hijacking.
<b>RPKI-ROV</b>	Xác thực nguồn gốc tuyến	Cơ chế tra sổ đăng ký xem prefix thuộc AS nào. Chỉ chống được origin hijacking.
<b>VP</b> (Vantage Point)	Điểm quan sát	Router chia sẻ bảng định tuyến cho kho công cộng (RIPE RIS, RouteViews).
<b>OPRT</b>	Cây định tuyến quan sát được của prefix	Cây gộp mọi đường đi từ các VP tới một prefix, gốc là origin AS. <b>Khái niệm trung tâm của bài báo.</b>
<b>Edit distance</b>	Khoảng cách chỉnh sửa	Chi phí biến cây này thành cây kia bằng thao tác thêm/xóa cạnh.
<b>Valley-free</b>	Luật không “thung lũng”	AS không nên chuyển tiếp tuyến nhận từ provider/peer sang provider/peer khác.
<b>Tier-1 AS</b>	AS cấp 1	AS xương sống, không phải mua kết nối từ ai.
<b>Content AS</b>	AS nội dung	AS của nhà cung cấp nội dung: Google, Amazon, Meta...
<b>Recall</b>	Độ phủ / độ nhạy	Tỷ lệ số vụ tấn công thật bị phát hiện.
<b>FPR</b> (False Positive Rate)	Tỷ lệ dương tính giả	Tỷ lệ sự kiện bình thường bị báo nhầm là tấn công.
<b>Precision</b>	Độ chính xác	Trong số cảnh báo đưa ra, bao nhiêu phần trăm là đúng.
<b>Route leak</b>	Rò rỉ định tuyến	AS vô tình quảng bá tuyến ra ngoài phạm vi chính sách — giống hijack nhưng không cố ý.
<b>Route Flap Damping</b>	Giảm chấn nhấp nháy tuyến	Cơ chế phạt các prefix bị quảng bá/rút liên tục.

Tài liệu giảng giải được biên soạn dựa trên bài báo gốc tại USENIX Security 2025.  
Mã nguồn và dữ liệu của nhóm tác giả: <https://doi.org/10.5281/zenodo.15589806>